

RELAZIONE DI ANALISI STATICA

Win32.Mydoom.a — file scan.c

Analisi del modulo di raccolta degli indirizzi email

1. Obiettivo dell'analisi

Il file scan.c costituisce il componente del sorgente Win32.Mydoom.a dedicato alla ricerca di indirizzi email presenti nei dati accessibili dalla macchina. L'analisi statica evidenzia come il modulo normalizzi il testo, individui candidati indirizzi email e li inoltri alla coda di mass-mailing gestita da massmail.c.

2. Collegamento con il mass-mailing

Il collegamento è esplicito nella funzione scan_out():

```
static void scan_out(const char *email)
{
    massmail_addq(email, 0);
    return;
}
```

L'indirizzo individuato dalla scansione viene quindi passato direttamente a massmail_addq(). Il modulo non effettua autonomamente l'invio: alimenta la coda che sarà successivamente gestita dal sottosistema massmail.

3. Normalizzazione del testo

Prima dell'estrazione, scantext_textcvt() modifica il contenuto letto per ricondurre alcune forme alterate a una rappresentazione più facilmente riconoscibile. Tra le conversioni presenti:

- "@" → "@"
- " @" → "@"
- "@@" → "@"
- "(@)" → "@"
- "(at)" → "@"
- " " e " " → spazio

Il codice richiama inoltre html_replace() e html_replace2(), mostrando che la routine è pensata per gestire anche contenuto testuale proveniente da sorgenti HTML.

4. Estrazione degli indirizzi

scantext_extract_ats() cerca il carattere @ e analizza i caratteri che lo precedono e lo seguono tramite la tabella mail_chars[]. Vengono applicati controlli sui caratteri ammessi, sulle estremità del candidato e sulla lunghezza minima.

```
if (mail_len < 7) continue;
...
scan_out(out_buf);
```

Il codice non dimostra da solo una validazione completa secondo gli standard moderni degli indirizzi email; dimostra invece chiaramente una procedura di estrazione di candidati da testo e il loro inoltro alla coda.

5. Scansione dei file di testo

`scan_textfile()` apre i file in lettura, li elabora a blocchi e applica in sequenza la normalizzazione e l'estrazione degli indirizzi. Se non viene trovato alcun indirizzo entro circa 300 KiB di dati letti, la scansione viene interrotta.

6. Tipi di file analizzati

Categoria	Esempi nel codice	Limite
Testo	txt	80 KiB
Testo	htm*, sht*, php*, asp*, dbx*, adb*, pl	200 KiB
Testo	tbb*	1200 KiB
Windows Address Book	wab*	8 MiB

La selezione viene effettuata da `scan_dir_file()`, che evita di trattare indistintamente ogni file e applica limiti dimensionali differenti a seconda del formato.

7. Scansione ricorsiva delle directory

`scan_dir1()` utilizza `FindFirstFile()/FindNextFile()` e attraversa ricorsivamente le directory fino alla profondità indicata dal parametro `max_level`. Le directory `.` e `..` vengono ignorate. Prima di scendere in una sottodirectory viene introdotto un ritardo di 75 ms.

8. Windows Address Book (WAB)

`scan_wab()` apre un file WAB, ne crea una mappatura in memoria e utilizza i dati presenti nell'header del formato per individuare le voci. Le stringhe estratte vengono passate a `scan_out()`, collegandole direttamente alla coda dei destinatari.

```
base1 = *((DWORD *) (ptr + 0x60));  
cnt = *((DWORD *) (ptr + 0x64));  
...  
scan_out(email);
```

9. Individuazione del WAB predefinito

`scan_default_wab()` legge dal Registro di Windows il percorso del WAB dell'utente corrente. Il percorso della chiave è memorizzato nel sorgente in forma ROT13 e viene decodificato prima dell'accesso.

```
rot13(key_path, "Fbsgjner\\Zvpefbfbsg\\JNO\\JNO4\\Jno Svyr Anzr");
```

Il codice analizzato supporta quindi esplicitamente la ricerca della rubrica WAB configurata per l'utente.

10. Temporary Internet Files

scan_ietemp() costruisce i percorsi dei Temporary Internet Files sia a partire dalla directory di Windows sia tramite %USERPROFILE%\Local Settings. Le directory vengono poi passate a scan_dir1() con profondità massima pari a 5.

11. Scansione delle unità locali

scan_disks() identifica l'unità contenente la directory di sistema e la sottopone a scansione ricorsiva con profondità 15. Successivamente esamina le unità da C: a Y:, escludendo quella di sistema e considerando le unità di tipo DRIVE_FIXED e DRIVE_RAMDISK. Prima delle unità aggiuntive viene eseguito Sleep(8096).

12. Controllo dell'attività di scansione

La variabile globale scan_freezed permette di sospendere temporaneamente l'attività. scan_freeze() imposta il flag e le routine di scansione attendono con Sleep(2048) quando il flag è attivo. Il meccanismo permette di coordinare la scansione con il resto del programma.

13. Flusso funzionale ricostruito

```
File / WAB / Temporary Internet Files
    ↓
normalizzazione del contenuto
    ↓
ricerca del carattere @
    ↓
estrazione candidato email
    ↓
scan_out()
    ↓
massmail_addq()
    ↓
coda mass-mailing
```

14. Valutazione

Le evidenze statiche mostrano che scan.c implementa una componente di raccolta degli indirizzi email da più fonti locali: file testuali, Windows Address Book, Temporary Internet Files e unità locali selezionate. Gli indirizzi vengono inoltrati direttamente alla coda del mass-mailing. Nel contesto dei moduli già analizzati, questa funzione costituisce quindi la fase di acquisizione dei destinatari, precedente alla generazione dei messaggi e alla loro consegna tramite DNS e SMTP.

15. Evidenze principali

Evidenza	Significato
massmail_addq(email, 0)	Passaggio degli indirizzi alla coda di mass-mailing
scantext_textcvt()	Normalizzazione di rappresentazioni alterate del testo

scantext_extract_ats()	Ricerca ed estrazione di candidati email
scan_wab()	Raccolta di indirizzi dal Windows Address Book
scan_default_wab()	Ricerca del WAB configurato tramite Registro
scan_ietemp()	Scansione dei Temporary Internet Files
scan_disks()	Scansione di unità locali selezionate
scan_dir1()	Attraversamento ricorsivo delle directory

Conclusione

scan.c è il componente di Win32.Mydoom.a responsabile della raccolta degli indirizzi email. La sua funzione è strettamente integrata con massmail.c: gli indirizzi individuati vengono inseriti nella coda dei destinatari, da cui le altre componenti possono procedere alla generazione e all'invio dei messaggi. Il codice fornisce pertanto una prova statica concreta della capacità del malware di reperire destinatari dalla macchina infetta.